

Oversight of Reporting Breaches of Personal Data Security

Date: 31-08-2023

Decision

Private Companies

No Criticism

Supervision / Self-initiated Case

Unintentional Disclosure

Unauthorized Access

Report of Breach of Personal Data Security

The Data Protection Agency has conducted 16 planned inspections focusing on municipalities' and banks' handling of breaches of personal data security. The Data Protection Agency found grounds to express criticism in two cases.

Journal Number: 2021-41-0138.

Danske Andelskassers Bank A/S (hereinafter Danske Andelskassers Bank) was among the companies that the Data Protection Agency selected for oversight in the autumn of 2021 under the General Data Protection Regulation[1] and the Data Protection Act[2].

The Data Protection Agency's oversight was a written inspection that focused on whether Danske Andelskassers Bank reports and documents breaches of personal data security in accordance with Article 33, paragraph 1, and Article 33, paragraph 5 of the General Data Protection Regulation, including the bank's processes for handling and recording breaches of personal data security. The oversight was based on an assessment of samples among unreported breaches as well as information about guidelines, procedures, and training activities, etc.

The oversight was announced by letter dated November 24, 2021, and the bank was simultaneously requested to respond to a number of questions. The Data Protection Agency informed about the background for the oversight, noting that a review of the agency's cases regarding reports of breaches of personal data security revealed that Danske Andelskassers Bank had reported significantly fewer breaches of personal data security per employee in the financial institution than other financial institutions.

By letter dated January 18, 2022, Danske Andelskassers Bank sent a statement in which the bank responded to the Data Protection Agency's questions. The bank's response was also accompanied by process descriptions and guidelines that the bank uses to comply with Article 33 of the General Data Protection Regulation.

Summary

In the summer and autumn of 2021, the Data Protection Agency initiated written inspections of the handling of breaches of personal data security by eight larger municipalities and eight larger banks. The inspections were organized such that the municipalities and banks were divided into two groups – those that had reported the most and the fewest breaches in relation to the municipalities' population and the number of employees in the banks.

"One of the new things that came with GDPR over five years ago was that data controllers, as a general rule, must report all breaches of personal data security to the Data Protection Agency within 72 hours, and they must internally document all breaches of personal data security, regardless of whether they need to be reported to the Data Protection Agency or not. Additionally, there has been an increased focus on what companies and authorities need to consider when customers' or citizens' information is mishandled by mistake," says Vibeke Dyssemark Thomsen, chief consultant at the Data Protection Agency, and continues: "This may, for example, lead to the need to implement new or additional security measures to reduce the risk of further breaches. Therefore, we have now conducted a service review of the area, where we have looked at the procedures and taken some samples. The conclusion is largely that the 16 selected municipalities and banks appear to have the right focus on complying with the rules."

The Group with the Most Reported Breaches

For the group with the most reported breaches, the inspections focused, among other things, on whether the municipalities and banks had taken appropriate security measures to reduce the number

of breaches of personal data security, where there had been unauthorized disclosure of personal data in connection with sending information to, among others, citizens, authorities, etc., including in relation to citizens with name and address protection and financial information.

Compliance with the rules on appropriate processing security will normally entail that:

The data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not come to the knowledge of unauthorized persons. The data controller must, in this regard, ensure that all employees in the organization are familiar with any internal procedures for handling personal data, including in relation to sending personal data to, among others, citizens, authorities, etc. Procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Data Protection Agency found, on the basis of the available evidence, that all data controllers had taken appropriate security measures. In its assessment, the Data Protection Agency emphasized that: Procedures, etc. had been developed and activities had been conducted to educate employees in data protection, including to ensure that they are aware that there should be no unintentional disclosure of personal data to an incorrect recipient.

They have considered and continuously implemented both technical and organizational measures following past breaches of personal data security to avoid similar breaches.

There is a strong focus on avoiding unintentional disclosure of confidential information, which is supported both by business processes, ongoing guidance, etc., and systematic measures, etc.

****Group with the Fewest Reported Breaches****

For the group with the fewest reported breaches, the inspections focused on whether the municipalities and banks report and document breaches of personal data security in accordance with the requirements of the General Data Protection Regulation (GDPR), including their processes for handling and recording breaches of personal data security.

The Data Protection Authority stated in these cases that it is the Authority's view that compliance with the rules that breaches of personal data security must, as a general rule, be reported to the Data Protection Authority within 72 hours implies that:

1. The data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly.
2. In this context, the data controller must ensure that all employees in the organization are familiar with internal procedures for handling breaches of personal data security to the necessary extent, and that relevant employees can identify, handle, and assess breaches of personal data security.

The Data Protection Authority found that all data controllers, overall, have adopted appropriate procedures and guidelines, etc., and have implemented appropriate training activities that can support compliance with the requirements in the GDPR regarding the reporting of breaches of personal data security. Thus, they can ensure that breaches of personal data security are captured within the organization so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as to document the breaches, including, among other things, the justification for not reporting them to the Data Protection Authority.

However, the Data Protection Authority noted in relation to all inspections that the Authority had not had the opportunity, as part of the inspection, to take a specific position on whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives.

Furthermore, the Data Protection Authority stated that the rule requiring the data controller to document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken, must ensure that the Data Protection Authority can verify that the provision regarding the reporting of breaches of personal data security is complied with. Therefore, data controllers should document their justifications for all significant decisions made as a result of the breach. This is particularly relevant if the data controller, after assessing the breach,

concludes that it does not need to be reported to the Data Protection Authority. The documentation should, in relation to this decision, include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of individuals.

****Criticism in Two Cases****

As mentioned, there is pronounced criticism in two of the cases – specifically regarding two municipalities that did not document all breaches of personal data security.

In one case, the Data Protection Authority expressed serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified during the period from May 25, 2018, to September 2019, and that the municipality cannot document whether the recorded security incidents since September 2019 constitute actual breaches of personal data security.

In the other case, the Data Protection Authority criticized Frederikshavn Municipality for not documenting how many breaches of personal data security the municipality identified in 2018.

The Data Protection Authority notes that the list of breaches – in addition to serving as documentation for the Data Protection Authority – should also be used by the data controller to gain an overview of which breaches typically occur in the organization, and based on that, to consider whether there is a need to implement new or supplementary measures to avoid or further reduce the risk of additional breaches. It also appears from the received consultation responses that several of the data controllers actively use the lists for this purpose.

****1. Decision****

After reviewing the submitted material, the Data Protection Authority finds reason to conclude that Danske Andelskassers Bank, overall, has adopted appropriate procedures and guidelines and has implemented appropriate training activities to correctly capture and handle breaches of personal data security, cf. Article 33 of the General Data Protection Regulation.

Below follows a detailed review of the information that has emerged in connection with the inspection, and a justification for the Data Protection Authority's decision.

****2. Justification for the Data Protection Authority's Decision****

****2.1. Relevant Legal Provisions****

A breach of personal data security is defined in Article 4, no. 12 of the General Data Protection Regulation as a breach of security that leads to accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data that has been transmitted, stored, or otherwise processed.

It follows from Article 33, paragraph 1 of the General Data Protection Regulation that in the event of a breach of personal data security, the data controller must without undue delay and...

may be classified as a breach of personal data security, as it does not involve the unauthorized disclosure of personal data that could compromise the rights and freedoms of individuals.

2.2. Assessment of Non-Reported Breaches

Danske Andelskassers Bank has, at the request of the Data Protection Authority, provided an account of the first three breaches of personal data security that occurred in 2021, which the financial institution failed to report to the Data Protection Authority.

The first incident involved an employee mistakenly sending an email containing an online banking user number, name, and information that the customer had applied for an approved overdraft and had approved/sent E-tax data to the bank, to a customer instead of to their colleague who had the same first and last name. The error occurred because the system suggested both employees and customers, and the employee was not aware that they had mistakenly selected a customer with the same name as the colleague. In assessing the nature of the breach, the bank emphasized whether it was deemed that the transmitted information could compromise the customer.

The second incident involved an employee at Letpension, who exchanges files with individual financial institutions, mistakenly placing Danske Andelskassers Bank's file for payments in a folder that could be accessed for approximately 26.5 hours by all financial institutions involved in the collaboration. The file contained personal identification numbers and financial information. Danske Andelskassers Bank has

stated that Spar Nord reported the breach to Letpension without accessing the folder, and there is no reason to believe that the other financial institutions, which are subject to confidentiality obligations, accessed the folder, thus the risk of compromise is considered unlikely. In assessing the nature of the breach, the bank emphasized that the information was only available for a short period to recipients who are subject to confidentiality obligations.

The third incident involved the fact that in connection with a data breach at BEC Financial Technologies, no information was forwarded to Danske Andelskassers Bank regarding any address protection for existing customers who had been assigned a new personal identification number. This is because when a customer changed their CPR number, they were not registered for CPR monitoring, meaning that BEC and thus the bank did not receive information about any registration of name and address protection. This could mean that the bank, in connection with transactions, provided protected address information or sent materials to an address where the customer no longer resides. After reviewing the affected customers, Danske Andelskassers Bank found that there had been no transfers that could have sent address information.

The Data Protection Authority does not find grounds to override Danske Andelskassers Bank's assessment that the first two incidents can be characterized as breaches of personal data security, according to the data protection regulation's Article 4, No. 12, but that these are not subject to the obligation to report.

Thus, the Data Protection Authority does not find grounds to override the assessment that it must be deemed unlikely that the relevant breaches pose a risk to the rights and freedoms of individuals, according to Article 33, paragraph 1.

The Data Protection Authority does not find that the third incident...

constitutes a breach of personal data security. The Data Protection Agency has emphasized that the reported incident does not constitute a breach of established security measures that have led to accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data that has been transmitted, stored, or otherwise processed, cf. the definition in Article 4, paragraph 1, number 12 of the General Data Protection Regulation.

2.3. Documentation, Procedures, and Employee Training

Danske Andelskassers Bank has stated in its statement of January 18, 2022, that since May 25, 2018, and up to the statement in the present case, a total of 39 breaches of personal data security have been identified at Danske Andelskassers Bank.

Furthermore, it appears from the statement of January 18, 2021, and the attached appendices, that Danske Andelskassers Bank has established procedures for how and to whom breaches of personal data security should be reported internally within the organization, whom employees can contact with questions about breaches, and who is responsible for receiving, handling, and assessing breaches as well as for reporting to the Data Protection Agency. It is also noted that internal documentation of breaches is carried out, including the justification for such breaches if they are not reported to the Data Protection Agency.

Additionally, it is indicated that Danske Andelskassers Bank has developed guidelines and conducted a number of activities to educate employees in data protection, including with the aim of enabling them to identify and handle any breaches of personal data security.

Danske Andelskassers Bank has also explained the criteria that are included in the bank's assessment of whether a breach of personal data security should be reported to the Data Protection Agency.

Based on the submitted material, including information about the three unreported breaches from 2021, the Data Protection Agency's immediate assessment is that Danske Andelskassers Bank has overall adopted appropriate procedures and guidelines, etc., and has conducted appropriate training activities that can support compliance with the requirements in Article 33 of the General Data Protection Regulation, thereby ensuring that breaches of personal data security are captured within the organization so that they can be assessed to determine whether the breach should be reported to the Data Protection Agency, as well as allowing for documentation of the breaches, including the justification for such if they are not reported to the Data Protection Agency.

It is noted that the Data Protection Agency has not had the opportunity, as part of its supervision, to

specifically assess whether all relevant employees have completed the relevant training activities, and that the Agency is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data. (Data Protection Act)